École La Passerelle des Métiers du Numérique (PMN)

Expert en architecture, systèmes, réseaux et sécurité informatique
Module PYS-701 – Python pour la sécurité · RNCP 38823 – bloc BC03

RAPPORT D'INVESTIGATION

Opération Brume – Nordis Logistique

Reconstitution d'une intrusion à partir de sept journaux, avec des scripts Python

Client : Nordis Logistique (entreprise fictive) – direction et SOC

Présenté par	**Priscilla MANEDJI NGOUANA**
Modalité	**Projet individuel (accord de l'intervenant)**
Dépôt des scripts	**operation-brume (Git)**
Date de rendu	**23 octobre 2026**

Données entièrement fictives fournies pour le cours : adresses IP de documentation, domaines en .example. Projet 100 % défensif.

Sommaire

1. Synthèse pour la direction 3
2. Méthode 4
  2.1 Données analysées 4
  2.2 Outils 4
  2.3 Démarche 4
  2.4 Hypothèses écartées 5
3. Chronologie de l'attaque 6
  3.1 Les recoupements qui fondent les conclusions 6
  3.2 Limites et incertitudes 7
4. Indicateurs de compromission 7
5. Impact 7
  5.1 Données exfiltrées 7
  5.2 Périmètre et gravité 8
  5.3 Pourquoi les alertes de l'EDR sont passées inaperçues 8
6. Recommandations 9
  6.1 Mesures correctives, par priorité 9
  6.2 Règles de détection proposées et testées 9
7. Annexes 10
  A. Reproduire l'analyse 10
  B. Extrait de script : détection d'une rafale d'échecs suivie d'un succès 10
  C. Usage de l'intelligence artificielle 10
  D. Bilan individuel 10

1. Synthèse pour la direction

> **En une phrase.** Un pirate a volé le mot de passe d'une salariée de la comptabilité par un faux courriel, s'est connecté la nuit au réseau pendant 9 jours, a pris le contrôle d'un compte d'administrateur, a copié **près de 0,9 Go de données** vers l'extérieur, puis a **supprimé les sauvegardes et chiffré les fichiers du serveur principal** dans la nuit du 19 au 20 septembre.

Que s'est-il passé ?

1. **Vendredi 11 septembre** : une salariée de la comptabilité reçoit un faux courriel de « facture impayée ». Elle ouvre le lien et saisit son identifiant et son mot de passe sur un faux site. Le soir même, le pirate se connecte au VPN de l'entreprise avec ce compte.
2. **Nuits du 12 au 14 septembre** : il explore le réseau, trouve un compte d'administrateur du service informatique, devine son mot de passe en quelques essais, puis crée un compte caché « svc_monitoring » doté des droits d'administration les plus élevés.
3. **Nuit du 18 au 19 septembre** : il envoie environ 0,9 Go de données de l'entreprise vers un site de stockage externe.
4. **Nuit du 19 au 20 septembre** : il supprime les sauvegardes, puis lance un rançongiciel qui chiffre les fichiers partagés du serveur du siège.

Qu'est-ce qui a été touché ?

- **3 comptes** : la salariée de la comptabilité (mot de passe volé), un administrateur informatique (mot de passe deviné), un compte créé par le pirate.
- **4 machines** : le poste de la comptabilité d'où sont parties les données, les deux serveurs de fichiers (Rouen, chiffré, et Lyon, visité par le pirate) et le serveur de sauvegarde.
- **Les données** : environ 0,9 Go copiés à l'extérieur ; leur contenu n'est pas visible dans les journaux.

Pourquoi personne n'a rien vu ?

Le système d'alerte a bien signalé l'attaque **à cinq reprises**, dès le premier jour. Mais 98 % de ses alertes habituelles sont de fausses alarmes, si bien qu'elles ne sont plus lues, et personne ne surveille la nuit ni le week-end, quand le pirate agissait. **L'attaque était visible 8 jours avant le sabotage.**

Que faire ?

Quand	Action	Effet
Immédiatement	Désactiver le compte du pirate, changer les mots de passe des deux comptes volés, bloquer ses adresses, restaurer depuis une sauvegarde hors ligne saine	Chasser le pirate et reprendre l'activité
Sous 72 h	Faire analyser les données volées et, si elles contiennent des données personnelles, notifier la CNIL	Obligation légale (RGPD)
Sous 1 mois	Double authentification résistante à l'hameçonnage, verrouillage après échecs, astreinte de nuit sur les alertes critiques	Empêcher la même attaque
Sous 3 mois	Mettre en service les 7 règles de détection proposées (testées : elles auraient alerté 8 jours avant)	Détecter tôt la prochaine fois

Tableau 1 – Plan d'action recommandé à la direction

2. Méthode

2.1 Données analysées

Fichier	Format	Lignes	Contenu	Période
vpn_auth.csv	CSV	2 087	Connexions au VPN : compte, IP, pays, résultat	31/08 – 20/09
ad_events.jsonl	JSON Lines	8 567	Authentifications Windows (4624, 4625, 4672, 4720, 4728)	31/08 – 20/09
proxy_web.csv	CSV	25 998	Navigation web sortante, octets envoyés et reçus	31/08 – 20/09
firewall.csv	CSV	58 975	Flux réseau autorisés et bloqués	31/08 – 20/09
mail_gateway.csv	CSV	1 848	Courriels : expéditeur, pièce jointe, score de risque	31/08 – 18/09
edr_alerts.json	JSON	208	Alertes de l'antivirus d'entreprise et leur statut	31/08 – 20/09
inventaire_parc.csv	CSV	308	300 postes et 8 serveurs : IP, propriétaire, site	—

Tableau 2 – Les sept sources (97 991 lignes au total)

Nordis Logistique compte **300 postes, 8 serveurs et 300 utilisateurs** sur trois sites (166 machines au siège de Rouen, 95 à Lyon, 47 à Lille). Les journaux couvrent **trois semaines**, du lundi 31 août au dimanche 20 septembre 2026.

2.2 Outils

Python 3.12 dans un environnement conda dédié, **pandas** pour le traitement des tableaux, **matplotlib** pour les graphiques, **pytest** pour les tests, **Git** pour l'historique. Le dépôt `operation-brume` contient un module par niveau de l'énoncé (`brume/`) et cinq scripts exécutables (`01_normale.py` à `05_chronologie.py`). Chaque ligne chargée garde son **fichier et son numéro de ligne d'origine** : chaque résultat s'affiche sous la forme `[fichier, ligne N] champ=valeur`, citable comme preuve. **Aucune réponse n'est codée en dur** : chaque compte, adresse ou hôte est déduit des données par l'étape précédente, ce qui rend l'analyse rejouable sur une variante des journaux.

2.3 Démarche

5. **Établir la normale** (`01_normale.py`) : volumes par jour et par heure, part des connexions VPN françaises, scores des courriels, taux de faux positifs. Ces repères servent de seuils.
6. **Partir d'un indice fort et suivre le fil** : courriel au score anormal → visite du lien → connexion VPN du même compte → même adresse IP dans l'AD → actions de cette adresse dans le pare-feu.
7. **Tout ramener sur une frise commune** (`05_chronologie.py`) et ne retenir que les faits **corroborés par au moins deux sources**.

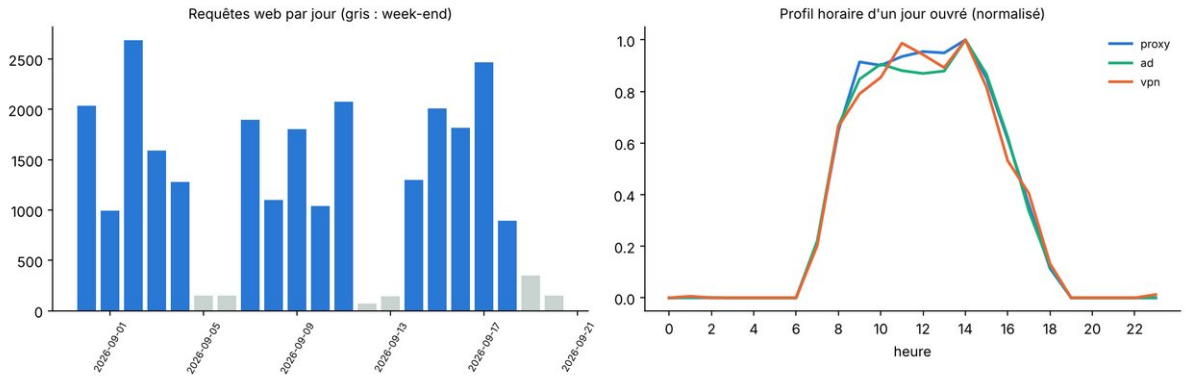


Figure 1 – La normale : activité en semaine de 7 h à 19 h, quasi nulle la nuit (01_normale.py)

Repère de la normale	Valeur	Anomalie observée
Connexions VPN depuis la France	99,7 %	6 connexions d'un même compte depuis 4 pays
Trafic web entre 20 h et 7 h	0,5 %	Toute l'activité de l'attaquant a lieu la nuit
Requêtes web un samedi	≈ 150	349 le samedi 19/09
Score de risque maximal d'un courriel livré	58	Seuil de blocage à 70 : le courriel piégé passe de justesse
Envoi web par hôte et par jour (99e centile)	0,26 Mo	894 Mo vers un hôte jamais vu
Alertes EDR closes comme faux positifs	98 %	Les 5 vraies alertes restent ouvertes

Tableau 3 – Repères de la normale et écarts constatés

2.4 Hypothèses écartées

Fausse piste	Pourquoi elle est écartée	Source
4 comptes créés (n.recrue2, n.recrue4, n.recrue9)	Créés en journée par le compte RH habituel depuis un poste interne : arrivées de salariés	ad_events.jsonl
364 échecs d'authentification	17 par jour en moyenne, isolés, depuis les postes des utilisateurs : fautes de frappe. Seules 2 rafales (≥ 5 en 10 min), toutes deux depuis l'IP de l'attaquant	ad_events.jsonl
203 alertes EDR (cloud, PowerShell, archives)	Closes comme faux positifs par un analyste avec un motif (sauvegarde personnelle, maintenance…)	edr_alerts.json
133 courriels de spam	Bloqués par la passerelle (score ≥ 70) : aucun n'a été délivré	mail_gateway.csv
Pays de connexion (BR, CN, NG, RU)	Une même IP change de pays en 3 minutes : la géolocalisation est fausse, seule l'IP est un indicateur fiable	vpn_auth.csv

Tableau 4 – Fausses pistes et raison de leur rejet

3. Chronologie de l'attaque

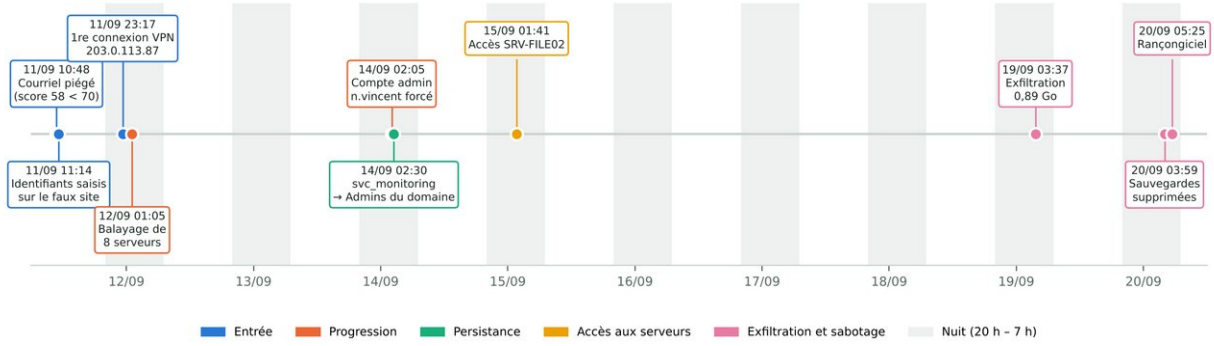


Figure 2 – Frise de l'attaque : l'attaquant n'agit que la nuit (bandes grises)

Date et heure	Fait établi	Preuve (fichier, ligne, champ)
Ven. 11/09 10:48	Courriel « Facture impayée » livré à l.perrin (comptabilité) : expéditeur sosie `fourniseur-x.example`, pièce jointe `facture_relance.pdf.htm`, lien vers `nordis-compta-auth.example`, score 58 (seuil 70)	mail_gateway.csv l. 1153 – expediteur, piece_jointe, score_risque, lien
11/09 11:14	l.perrin ouvre la fausse page (GET) puis **envoie le formulaire** (POST) depuis PC-SIE-1000	proxy_web.csv l. 15405, 15408 – methode, url, categorie=hameconnage
11/09 11:20	L'EDR signale « page d'hameçonnage visitée » – **resté ouvert**	edr_alerts.json l. 119 – statut
11/09 23:14–23:17	203.0.113.87 tente le VPN avec l.perrin : 2 échecs (« second facteur manquant »), puis **succès**	vpn_auth.csv l. 1347–1349 – ip_source, resultat, motif
Sam. 12/09 00:58–01:08	Avec l.perrin, l'attaquant tente 6 serveurs : **accès refusé** (compte sans droits)	ad_events.jsonl l. 5539–5544 – event_id 4625, motif
12/09 01:05	**Balayage** depuis 10.10.200.41 (absente de l'inventaire) : 8 serveurs × 5 ports (22, 389, 445, 1433, 3389) en 25 s	firewall.csv l. 32227–32266 – ip_source, ip_dest, port_dest
Lun. 14/09 02:01–02:05	8 échecs en 2 min sur **n.vincent** (informatique, Lille) depuis 203.0.113.87, puis succès et privilèges spéciaux	ad_events.jsonl l. 5651–5660 – event_id 4625, 4624, 4672
14/09 02:29–02:30	n.vincent crée **svc_monitoring** et l'ajoute aux **Admins du domaine**	ad_events.jsonl l. 5661–5662 – 4720, 4728, groupe
14/09 02:57	L'EDR signale « création de compte à privilèges hors procédure » – **resté ouvert**	edr_alerts.json l. 147
Nuits des 14, 15, 19, 20/09	Sessions RDP depuis 10.10.200.41 et connexions de svc_monitoring vers SRV-FILE01, SRV-FILE02, SRV-BACKUP01	firewall.csv (port 3389), ad_events.jsonl l. 6199, 8422, 8503
Sam. 19/09 03:37–04:04	**Exfiltration** : 140 envois (POST /upload/chunk) vers `cloud-depot-securise.example`, 0,89 Go, depuis PC-SIE-1000	proxy_web.csv l. 25503–25642 – host, octets_envoyes
19/09 04:14	L'EDR signale « exfiltration de données probable » – **resté ouvert**	edr_alerts.json l. 189
Dim. 20/09 03:59	**Suppression des sauvegardes** sur SRV-FILE01 (arrêt du service, points de restauration effacés)	edr_alerts.json l. 202
20/09 05:25	**Rançongiciel** sur SRV-FILE01 : chiffrement massif des partages réseau, sous le compte svc_monitoring	edr_alerts.json l. 203

Tableau 5 – Chronologie prouvée (extrait de resultats/chronologie.csv, produit par 05_chronologie.py)

3.1 Les recoupements qui fondent les conclusions

- **Courriel → clic → VPN** : même compte (l.perrin), 26 minutes entre réception et clic, connexion de l'attaquant 12 heures plus tard. Trois sources indépendantes.
- **L'adresse interne 10.10.200.41 appartient à l'attaquant** : elle est absente de l'inventaire, et ses actions tombent pendant les sessions VPN de 203.0.113.87, jamais pendant celles d'un autre utilisateur (`03_progression.py`, rattachement aux sessions).
- **La même adresse 203.0.113.87** apparaît dans le VPN (l.perrin), dans l'AD (force brute sur n.vincent, création de svc_monitoring) et dans les connexions de svc_monitoring : un seul et même acteur.

- **L'anomalie du samedi 19/09** (349 requêtes web au lieu de 150) est entièrement expliquée par les 140 envois d'exfiltration : deux angles d'analyse, une même conclusion.

3.2 Limites et incertitudes

- **Contournement du MFA** : l'attaquant échoue deux fois sur le second facteur puis réussit à 23:17. Les journaux ne disent pas comment : code capturé par la fausse page ou notification validée par lassitude. Non tranché.
- **14 actions de 10.10.200.41 hors des sessions VPN journalisées** (par exemple le 14/09 à 01:17, avant la connexion de 01:38). Soit des sessions n'ont pas été journalisées, soit l'attaquant disposait d'un autre accès. Le rattachement reste très probable mais pas certain.
- **Prise de contrôle de PC-SIE-1000** pour l'exfiltration : le compte, l'horaire et l'alerte EDR concordent, mais aucun journal ne montre la session utilisée sur ce poste.
- **Contenu des données volées** : seul le volume est connu. Les journaux de fichiers des serveurs seraient nécessaires pour savoir lesquelles.

4. Indicateurs de compromission

Type	Valeur	Rôle	Sources
Adresse IP externe	203.0.113.87	Connexions VPN et AD de l'attaquant	vpn_auth, ad_events
Adresse IP interne	10.10.200.41	Adresse VPN attribuée à l'attaquant, absente de l'inventaire	firewall
Domaine	fourniseur-x.example	Expéditeur sosie de fournisseur-x.example	mail_gateway
Domaine	nordis-compta-auth.example	Page d'hameçonnage	mail_gateway, proxy_web, edr
Domaine	cloud-depot-securise.example	Destination de l'exfiltration	proxy_web, edr
Fichier	facture_relance.pdf.htm	Pièce jointe à double extension	mail_gateway
Compte	l.perrin	Compromis par hameçonnage (entrée)	mail, proxy, vpn, ad
Compte	n.vincent	Administrateur compromis par force brute	ad_events
Compte	svc_monitoring	Créé par l'attaquant, membre des Admins du domaine	ad_events, edr
Machine	PC-SIE-1000	Poste d'où sont parties les données	proxy_web, edr
Machine	SRV-FILE01, SRV-FILE02	Serveurs de fichiers accédés ; SRV-FILE01 chiffré	firewall, ad_events, edr
Machine	SRV-BACKUP01	Serveur de sauvegarde accédé avant la suppression	firewall, ad_events

Tableau 6 – Indicateurs de compromission (resultats/iocs.csv)

5. Impact

5.1 Données exfiltrées

Le samedi 19 septembre, de **03:37 à 04:04**, **894 393 390 octets, soit 0,89 Go (0,83 Gio)**, sont envoyés en 140 morceaux vers `cloud-depot-securise.example`, sous le compte l.perrin, depuis PC-SIE-1000. Cet hôte n'avait jamais été visité ; il a reçu **377 fois** plus de données que l'hôte médian sur trois semaines. Le découpage en morceaux d'environ 6 Mo et l'horaire nocturne visent à passer sous les radars.

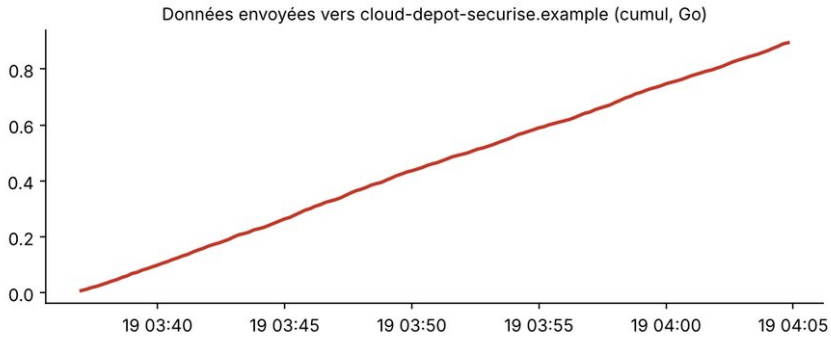


Figure 3 – Cumul des données envoyées vers l'hôte d'exfiltration (04_impact.py)

5.2 Périmètre et gravité

Domaine	Constat	Gravité
Confidentialité	0,89 Go volés, contenu inconnu ; double extorsion possible (chiffrement + menace de publication)	Critique
Disponibilité	Partages de SRV-FILE01 (Rouen) chiffrés ; sauvegardes supprimées ; SRV-FILE02 (Lyon) et SRV-BACKUP01, visités les mêmes nuits, à contrôler	Critique
Intégrité des accès	Un compte membre des Admins du domaine contrôlé par l'attaquant : tout l'annuaire est à considérer comme compromis	Critique
Durée d'exposition	8 jours et 18 heures entre le courriel et le chiffrement, 5 alertes ignorées	Élevée

Tableau 7 – Évaluation de l'impact

5.3 Pourquoi les alertes de l'EDR sont passées inaperçues

- **Fatigue d'alerte** : 203 alertes sur 208 (98 %) sont des faux positifs ; l'équipe ne les traite plus une à une.
- **Aucune surveillance hors heures ouvrées** : les 4 alertes critiques sont tombées entre 02:57 et 05:25, dont 3 un week-end.
- **La seule alerte en journée était de gravité « moyenne »** (page d'hameçonnage, 11/09 11:20). La traiter aurait permis de bloquer le compte **12 heures avant** l'entrée de l'attaquant.
- **Les outils voyaient, sans bloquer** : le proxy avait classé le site d'hameçonnage en « hameconnage » et l'exfiltration en « transfert_suspect », mais les a laissés passer.

6. Recommandations

6.1 Mesures correctives, par priorité

Priorité	Mesure	Ce qu'elle aurait empêché
P1 – immédiat	Désactiver svc_monitoring ; réinitialiser l.perrin et n.vincent ; réinitialiser deux fois le compte krbtgt ; bloquer les IoC ; isoler PC-SIE-1000 ; restaurer depuis une sauvegarde hors ligne	Le maintien de l'attaquant
P1 – 72 h	Analyse des données volées et notification à la CNIL si elles contiennent des données personnelles	Le risque juridique
P2 – 1 mois	MFA résistant à l'hameçonnage (clés FIDO2) sur le VPN et les comptes d'administration	La connexion du 11/09
P2 – 1 mois	Verrouillage du compte après 5 échecs ; comptes d'administration séparés et sans accès VPN direct	La force brute du 14/09
P2 – 1 mois	Astreinte sur les alertes critiques, nuit et week-end, avec délai de prise en charge défini	Les 4 alertes critiques ignorées
P2 – 1 mois	Proxy en mode blocage pour les catégories « hameconnage » et « transfert_suspect »	Le clic et l'exfiltration
P3 – 3 mois	Sauvegardes immuables ou hors ligne, testées par une restauration régulière	La perte des sauvegardes
P3 – 3 mois	Réglage de l'EDR pour réduire les faux positifs ; inventaire à jour du pool d'adresses VPN	La fatigue d'alerte

Tableau 8 – Mesures correctives priorisées

6.2 Règles de détection proposées et testées

Chaque règle est codée dans `brume/regles.py` et **rejouée sur les trois semaines** de journaux par `05_chronologie.py`. On mesure son avance sur le sabotage (20/09 03:59) et le nombre d'alertes qu'elle aurait produites.

Règle	Alertes en 3 semaines	Première alerte	Avance sur le sabotage
R1 Courriel livré avec domaine sosie ou double extension	1	11/09 10:48	8 j 17 h
R2 VPN réussi hors de France ou IP à pays multiples	4	11/09 23:17	8 j 4 h
R3 Adresse interne absente de l'inventaire	5	12/09 01:05	8 j 2 h
R4 Balayage : ≥ 10 couples IP:port en 1 min	1	12/09 01:05	8 j 2 h
R5 Rafale ≥ 5 échecs puis succès en 15 min	1	14/09 02:05	6 j 1 h
R6 Ajout à un groupe admin ou création de compte la nuit	2	14/09 02:29	6 j 1 h
R7 Envoi ≥ 100 Mo par jour vers un même hôte	1	19/09 03:37	1 j 0 h

Tableau 9 – Évaluation des règles (resultats/regles_detection.csv)

Lecture. Toutes les règles détectent l'attaque, et les quatre premières dès la première nuit, **plus de 8 jours avant le sabotage**, pour 15 alertes en tout sur trois semaines (contre 208 pour l'EDR actuel). **Limite assumée :** ces règles ont été mises au point sur les mêmes données que celles qui servent à les évaluer ; leur absence de fausses alertes est donc optimiste. Avant de les déployer, il faut les valider sur d'autres périodes et accepter quelques faux positifs, par exemple pour R2 avec les salariés en déplacement à l'étranger.

7. Annexes

A. Reproduire l'analyse

```
conda create -n brume python=3.12 -y && conda activate brume
pip install -r requirements.txt          # pandas, matplotlib, pytest
python3 01_normale.py                    # niveau 1 : la normale
python3 02_entree.py                     # niveau 2 : point d'entrée
python3 03_progression.py                # niveau 3 : progression
python3 04_impact.py                     # niveau 4 : impact
python3 05_chronologie.py                # niveau 5 : frise, IoC, règles
python3 -m pytest -q                     # 6 tests (logique des règles et cohérence)
```

B. Extrait de script : détection d'une rafale d'échecs suivie d'un succès

Pour chaque couple (compte, source), la fonction cherche au moins 5 échecs (4625) en 10 minutes, puis un succès (4624) du même compte depuis la même source dans les 15 minutes. C'est elle qui révèle la force brute sur n.vincent.

```
def rafales_echecs(ad, seuil=5):
    echecs = ad[ad["event_id"] == 4625].sort_values("horodatage")
    succes = ad[ad["event_id"] == 4624]
    for (user, src), grp in echecs.groupby(["utilisateur", "ip_source"]):
        t = grp["horodatage"].reset_index(drop=True)
        for i in range(len(t)):
            fen = t[(t >= t[i]) & (t <= t[i] + FENETRE_RAFALE)]      # 10 minutes
            if len(fen) >= seuil:
                ok = succes[(succes["utilisateur"] == user) & (succes["ip_source"] == src)
                            & (succes["horodatage"] > fen.max())
                            & (succes["horodatage"] <= fen.max() + DELAI_SUCCES)]
                ...  # enregistre la rafale, avec ses numéros de ligne comme preuve
```

C. Usage de l'intelligence artificielle

Conformément à l'énoncé, j'ai utilisé un assistant d'IA générative (Claude, d'Anthropic) pour structurer le code et le rapport. J'ai exécuté chaque script sur les données, lu et vérifié chaque résultat, et je sais relancer et expliquer chaque étape. Les conclusions et les limites reflètent ma lecture des preuves.

D. Bilan individuel

Ce qui m'a surprise. Les attaquants ne travaillent que la nuit : toute leur activité tombe entre 23 h et 5 h, en dehors des heures où quelqu'un regarde. C'est ce décalage, plus que la technique, qui leur a permis de rester 9 jours dans le réseau. J'ai aussi été frappée de voir que les outils avaient tout vu (EDR, proxy) sans que personne ne réagisse.

Ce que j'ai appris. À automatiser l'analyse : avec pandas, des questions impossibles à traiter à la main sur près de 100 000 lignes deviennent quelques lignes de code rejouables. J'ai appris à commencer par décrire la normale, à recouper les sources avant de conclure et à citer une preuve pour chaque affirmation, y compris pour écarter une fausse piste.

Pour aller plus loin. Avec plus de temps, je transformerais les sept règles en règles **Sigma**, un format standard importable dans un SIEM comme Wazuh, et je les ferais tourner chaque nuit sur les nouveaux journaux, avec une alerte envoyée à l'astreinte. Je les validerais aussi sur d'autres semaines pour mesurer leurs vrais faux positifs.